PENSE-BÊTE · TECHNIQUE ET COMMANDES

Authentification Active Directory

06-630 PSE 25-27 5-5 Active Directory - Authentification (Kerberos, NTLM, LDAP, MFA) — source : fiche de révision du module (gemma4, 03/11/2026)

À RETENIR

1. Kerberos est le protocole d'authentification par défaut reposant sur un système de tickets délivrés par le KDC.
2. Les stratégies de mot de passe affinées FGPP permettent d'appliquer des règles de complexité spécifiques à des groupes d'utilisateurs.
3. L'authentification MFA n'est pas un composant natif d'AD DS sur site et nécessite une intégration via NPS, AD FS ou des solutions tierces.

Fondamentaux de l'authentification AD

Notion	À retenir
AD DS	Technologie par défaut pour stocker les **informations d'identité** et les **clés cryptographiques** servant d'informations d'identification.
Processus cryptographique	Comparaison de **données signées** à une **clé cryptographique connue** (via mot de passe, jetons, certificats ou biométrie).
Architecture et flux	Le client (`Winlogon`) contacte le **DC** (hébergeant le **KDC** et le magasin) pour obtenir un **ticket de service** à présenter au **serveur de ressources**.

Protocoles d'authentification AD

Notion	À retenir
Kerberos et KDC	Protocole par défaut depuis **Windows 2000**. Le **KDC** (intégré au contrôleur de domaine) délivre un **TGT** pour obtenir ensuite un **ticket de service** validable par le serveur.
NTLM et sécurité	Mécanisme défi-réponse (obsolète). **NTLMv1** (56 bits) est vulnérable ; **NTLMv2** (128 bits) est amélioré. Risques : **pass-the-hash** et **relais NTLM**. Configurer : envoyer uniquement la réponse **NTLMv2**.
LDAP, SASL et PKINIT	LDAP utilise des **bind** (**simple bind** = mot de passe en clair). **SASL** encapsule Kerberos/NTLM via **SPNEGO** ou **GSSAPI**. **PKINIT** utilise certificats **X.509** (via **AD CS**) avec **EKU** authentification client.

Gestion des politiques de sécurité des comptes

Notion	À retenir
Stratégies de mot de passe par défaut	Appliquée via la **stratégie de groupe par défaut du domaine**. Paramètres : longueur **12** caractères, durée de vie **90** jours, historique de **24** mots de passe (l'**ANSSI** et le **NIST** déconseillent le renouvellement périodique sans incident).
Mise en œuvre des FGPP	Applique des règles spécifiques à des **groupes d'utilisateurs**. Pour comptes privilégiés : durée de vie **30** à **45** jours et longueur minimale de **14** caractères.
Mécanismes de verrouillage	Seuil recommandé : **5** échecs. Durée de verrouillage préconisée : **30** minutes. Identification des échecs via l'**ID d'événement 4625**.

Sécurisation et MFA

Notion	À retenir
Intégration de la MFA via NPS, AD FS et solutions tierces	MFA non native sur AD DS. Utilisation de l'extension **NPS** (proxy **RADIUS** vers **Microsoft Entra ID**), **AD FS** (fédération et **MFA conditionnelle**) ou solutions tierces (**Duo**, **RSA SecurID**) via agents/modules.
Bonnes pratiques de sécurisation de l'environnement AD	Désactiver **NTLMv1** (utiliser **NTLMv2**). Privilégier **LDAPS** (port **636**) ou **SASL** au lieu de LDAP clair. MFA pour les accès privilégiés et distants.
Surveillance et audit des événements de sécurité	Activer l'audit via **stratégie de groupe**. ID : **4624** (connexions réussies), **4625** (échecs de connexion), **4776** (validation des identifiants par le **DC**).

Dépannage Authentification AD

Notion	À retenir
Échecs Kerberos	Désynchronisation horaire (max **5 minutes**) ; utiliser `w32tm /resync` ; vérifier enregistrements **SRV DNS** ou redémarrer **Netlogon**.
Problèmes SPN	Échec Kerberos avec succès NTLM : vérifier **SPN** avec `setspn -L` ou ajouter avec `setspn -A` ; tester avec `klist get`.

Commandes de diagnostic et réparation

Commande	À quoi ça sert
`w32tm /resync`	synchroniser l'heure avec le contrôleur de domaine
`setspn -L [nom_compte]`	vérifier les **SPN** existants d'un compte d'ordinateur
`setspn -A [service] [FQDN] [compte]`	ajouter manuellement un **SPN** (service, FQDN et compte cible)
`klist get [SPN]`	tenter d'obtenir un ticket spécifique et afficher les erreurs
`klist`	afficher les tickets Kerberos en cache sur la machine
`Test-ComputerSecureChannel -Verbose`	vérifier et réparer le canal sécurisé avec le contrôleur de domaine
`Unlock-ADAccount`	déverrouiller un compte utilisateur ou restaurer l'accès

Pièges et confusions

- ⚠ Confondre le simple bind LDAP qui envoie le mot de passe en clair avec le mécanisme SASL qui sécurise les échanges.
- ⚠ Utiliser NTLM alors que Kerberos est le protocole par défaut et recommandé pour les domaines modernes.
- ⚠ Ignorer la synchronisation horaire alors qu'un décalage de plus de cinq minutes peut bloquer l'authentification Kerberos.
- ⚠ Confondre les stratégies de mot de passe classiques de la Default Domain Policy avec les stratégies affinées FGPP.
- ⚠ Croire que l'authentification MFA est un composant natif d'AD DS sur site.

Sigles et définitions

AD DS — services de domaine Active Directory servant à stocker les informations d'identité et les clés cryptographiques

Kerberos v5 — protocole d'authentification par défaut reposant sur un système de tickets et un centre de distribution de clés

KDC — centre de distribution de clés intégré au contrôleur de domaine

NTLM — ancien protocole d'authentification basé sur un mécanisme de défi-réponse

LDAP — protocole utilisé pour interroger et modifier les données de l'annuaire

MFA — authentification multifacteur exigeant au moins deux preuves d'identité distinctes

FGPP — stratégies de mot de passe affinées pour appliquer des règles de complexité spécifiques à des groupes

SPN — nom de principal de service devant être correctement enregistré pour Kerberos

Auto-test

1. Quel est le protocole d'authentification par défaut dans les domaines Active Directory ?
2. Quel est le décalage horaire maximal autorisé pour éviter de bloquer l'authentification Kerberos ?
3. Quel est l'ID d'événement pour identifier les échecs de connexion ?
4. Quelle commande PowerShell permet de vérifier et réparer le canal sécurisé ?
5. Quelle est la longueur minimale de mot de passe recommandée pour les comptes privilégiés via FGPP ?

Réponses : **1.** Kerberos v5 · **2.** cinq minutes · **3.** 4625 · **4.** Test-ComputerSecureChannel -Verbose · **5.** 14 caractères

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.